10.05.2024

Romsis Yazılım A.Ş.

Pegasus Cafe Mobil Uygulama Sızma Testi Raporu v1.0

Sızma Testi Tarihi:

26.04.2024 – 10.05.2024

RSU
Bilişim ve Danışmanlık

GİZLİ

İçindekiler

YÖNETİCİ ÖZETİ 2
Test Kapsamı 5
Uyarı 6
Sızma Testi Metodolojisi 7
Mobil Uygulama Sızma Testi Kontrol Listesi 8
Kullanılan Araçlar 8
MOBİL UYGULAMA SIZMA TESTİ BULGULARI 9
1. Acil Seviye Mobil Uygulama Sızma Testi Bulguları 9
2. Kritik Seviye Mobil Uygulama Sızma Testi Bulguları 9
3. Yüksek Seviye Mobil Uygulama Sızma Testi Bulguları 9
4. Orta Seviye Mobil Uygulama Sızma Testi Bulguları 9
4.1. Uygulamada Güvensiz Veri Depolanması 9
5. Düşük Seviye Mobil Uygulama Sızma Testi Bulguları 13
5.1. Uygulama Hata Mesajlarında Bilgilerin Erişilebilir Olması 13
5.2. Mobil Uygulama Debugging Özelliğinin Aktif Olması 14
5.3. Yetki Kontrolü Eksikliği 15

YÖNETİCİ ÖZETİ

Romsis Yazılım A.Ş.'ye ait (Kurum) risklerinin belirlenebilmesi için, kapsamda belirtilen Pegasus Cafe mobil uygulamasına (Android) standart kullanıcı ve admin yetkileri ile sızma testleri gerçekleştirilmiştir. Bu testler sonucunda Kurum bilgi varlıklarının güvenliğini etkileyen Acil ve Kritik seviyede bulgu tespit edilmemiştir. Tespit edilen zafiyetler uygulama sıkılaştırmaları ile alakalı olup çoğunlukla gizliliğin bozulması etkisine sebep vermektedir.

Genel olarak bulgular dikkate alındığında, Kurumun aşağıdaki konularda gelişmeye açık yönleri olduğu değerlendirilmektedir:

- Güvenli Yazılım Geliştirme ve Test Süreci
- Uygulama Güvenlik Sıkılaştırma Süreci

Çalışma sonucunda, 1 Orta ve 3 Düşük seviye olmak üzere toplam 4 bulgu tespit edilmiştir. Bulgu dağılımı incelendiğinde, Kurumun güvenlik ürünlerini efektif kullandığı, Kritik zafiyet oluşturabilecek önlemleri genel olarak aldığı ancak güvenli yazılım geliştirme ve sunucu/ağ yapılandırmalarının düzenli sıkılaştırmaları konularında eksiklerinin olduğu görülmektedir. Uygulamalarda hata mesajlarının yönetilmemesi bu duruma örnek olarak gösterilebilir.

Tavsiye Özeti:

Kurum bünyesinde güvenli yazılım geliştirme yaşam döngüsünün uygulanması, Kurumun verdiği hizmetlerin akışına göre uygulamaların gözden geçirilmesi bulguların büyük kısmının kapatılmasını sağlayacaktır. Sunucu ve servis sıkılaştırmaları ile güvenlik çözümlerinin bir arada kullanılması sayesinde Kurumun siber güvenlik seviyesinin artması ve olası bir siber olaya karşı hazır olması sağlanabilir.

GİZLİ

Mobil Uygulama Sızma Testi Bulguları

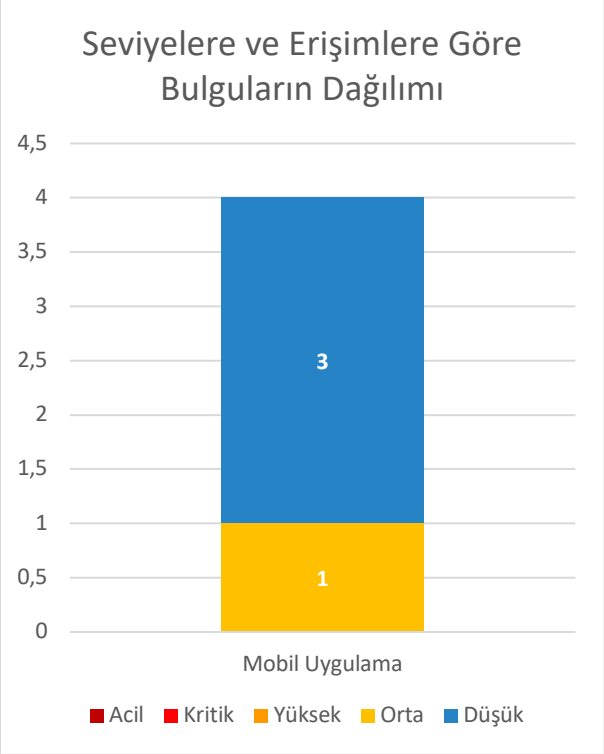
Seviye	Bulgu Adı	Etkilenen Sistem Sayısı
ORTA	Uygulamada Güvensiz Veri Depolanması	1
DÜŞÜK	Uygulama Hata Mesajlarında Bilgilerin Erişilebilir Olması	1
DÜŞÜK	Mobil Uygulama Debugging Özelliğinin Aktif Olması	1
DÜŞÜK	Yetki Kontrolü Eksikliği	1

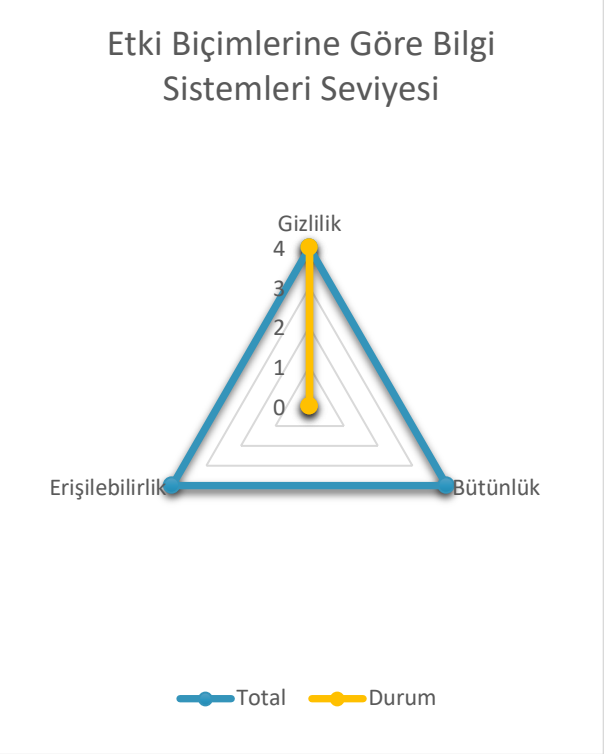
Bulgu Seviyeleri

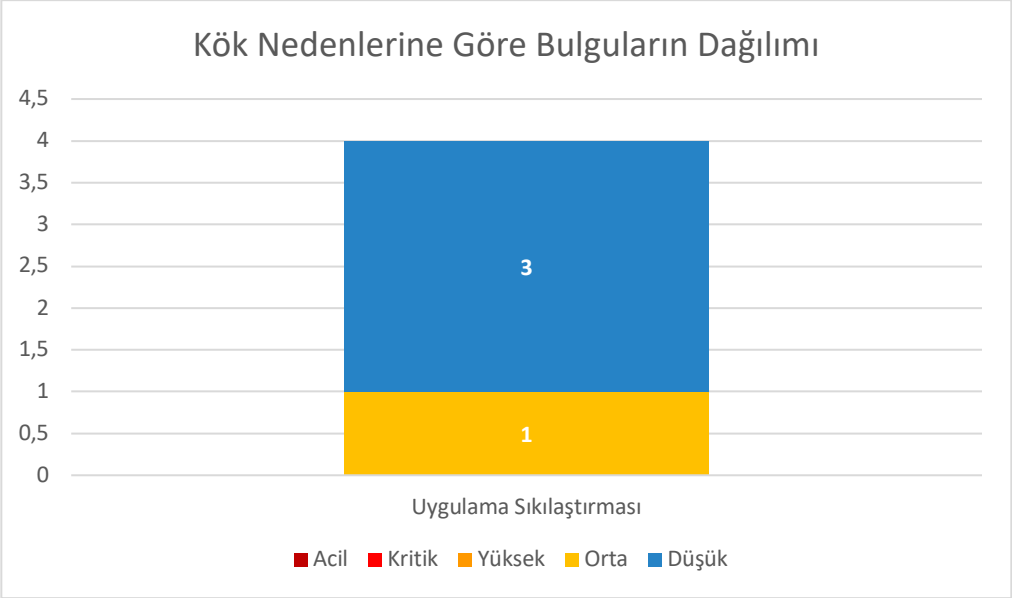
Seviye	Açıklama
ACİL	Saldırganların tam yetki ile uzaktan komut çalıştırmaya, servis dışı bırakma saldırıları gerçekleştirmeye veya kritik verilerin sızdırılması ile sonuçlanabilecek zafiyetlerdir.
KRİTİK	Düşük yetki ile komut çalıştırma, servis aksatma ve siber saldırganların daha büyük saldırıları yapmasına olanak tanıyan zafiyetlerdir.
YÜKSEK	Hedef sistem üzerinde diğer zafiyetlerde kullanılabilecek bilgileri açığa çıkaran, tetiklenmesi durumunda kaynak kullanımını arttırabilecek zafiyetlerdir.
ORTA	Tek başına zafiyet olarak değerlendirilmeyen fakat diğer zafiyetler ile kullanıldığında önemli olabilecek zafiyetlerdir.
DÜŞÜK	Bilgi seviyesinde önerilerdir. Sektör ile ilgili en iyi yapılandırmalar göz önüne alınarak belirtilen sistem sıkılaştırmalarıdır.

GİZLİ

Bulgu Grafikleri







Kök Nedenler

Kök Neden	Açıklama
Uygulama Sıkılaştırması	Uygulamaların üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular

GİZLİ

Test Kapsamı

Testi Gerçekleştiren Firma RSU Bilişim ve Danışmanlık Hizmetleri A.Ş.		**Test Kapsamı Veri Sahibi Firma** Romsis Yazılım A.Ş.
Testi Gerçekleştiren Personel Ömer Akincir		**Sorumlu Personel** Melihcan Yıldız
Raporu Hazırlayan Ömer Akincir	**Raporu Kontrol Eden** Kayhan Kayıhan	**Raporu Yayınlayan** Yıldız Balatürk Erkan
Test Başlangıç Tarihi 26.04.2024		**Raporlama Tarihi** 10.05.2024
Test Kapsamı Mobil Uygulama Sızma Testi - Pegasus Cafe (Android)		**Test Profili** Erişim: İnternet Profil: Standart Kullanıcı / Yönetici Profili
Testte Kullanılan Kaynaklar İnternet: - 185.124.86.25/29		**Test Hesapları** Test Kullanıcıları: - 11679 - 11687 - 2239 - 2254 - 2256 - 2401 - 2839 - 4524

Uyarı

Rapor içeriği gizli olup iki tarafın yazılı mutabakatı olmadan üçüncü taraflara basılı olarak ya da elektronik ortamda transfer edilemez veya paylaşılamaz.

Rapor, tarama süresi içinde varlığı bilinen veya tarafımızdan tespit edilen güvenlik açıklıklarını içerecektir. Tarama işlemi bittikten sonra rapor teslim edilene kadar geçen süre içerisinde çıkabilecek yeni güvenlik açıklarına dair eksikliklerden dolayı RSU sorumlu tutulamaz.

Rapor içinde yer alan çözüm önerilerine konu hakkında fikir verme amaçlı yer verilmiştir. Çözüm önerilerinin uygulanması sebebi ile çıkabilecek problemlerden RSU sorumlu tutulamaz. Önerilerde sunulan değişikliklerden gerçekleştirilmeden önce konu hakkında uzman kişilerden destek alınması tavsiye edilir.

Sızma Testi Metodolojisi

Gerçekleştirilen sızma testi, OWASP (Açık Web Uygulaması Güvenlik Projesi) ve NIST (Ulusal Standartlar ve Teknoloji Enstitüsü) tarafından sağlanan yönergelerle uyumlu metodoloji çerçevesinde yürütülmüştür.

1. **Hazırlık Aşaması:**
    a. Sızma testinin kapsamının ve hedeflerinin belirlemesi.
    b. İlgili paydaşlardan yazılı yetkilerin alınması.
    c. Hedef sistemler ve uygulamalar hakkında ilgili bilgilerin toplanması.
    d. Uygulanabilir yasal veya düzenleyici gerekliliklerin belirlenmesi.
2. **İstihbarat Toplama:**
    a. Hedefle ilgili erişilebilir bilgilerin elde edilmesi.
    b. Ağ altyapısı, uygulamalar ve hizmetler hakkında bilgi toplanması için araçlar ve teknikler kullanılması.
    c. Potansiyel zafiyetlerin, güvenlik açıklarının ve saldırı vektörlerinin belirlenmesi.
3. **Tehdit Modelleme:**
    a. Hedef sistemlerin mimari yönlerinin analiz edilmesi ve potansiyel tehditlerin belirlenmesi.
    b. Potansiyel etkilerine ve olasılıklarına göre önceliklendirilen tehditlerin belirlenmesi.
    c. Saldırganlar için saldırı yüzeyinin ve potansiyel giriş noktalarının belirlenmesi.
4. **Zafiyet Analizi:**
    a. Otomatik araçlar ve manuel teknikler kullanılarak kapsamlı bir zafiyet değerlendirmesi yapılması.
    b. Hedef sistemlerde ve uygulamalarda tespit edilen zafiyetlerin belirlenmesi ve doğrulanması.
    c. Seviyeleri, potansiyel etkileri ve düzeltme adımlarını içeren kanıtların oluşturulması.
5. **İstismar:**
    a. Tespit edilen zafiyetlerin istismar edilerek yetkisiz erişim elde edilmesi veya hedef sistemler ile etkileşim girişiminde bulunulması.
    b. Etik hackleme teknikleri kullanılarak tespit edilen zafiyetlerin varlığının ve etkisinin doğrulanması.
    c. Başarılı istismar girişimlerinin adımlarının ve sonuçlarının belgelenmesi.
6. **İstismar Sonrası:**
    a. Elde edilen sistemlerde daha fazla bilgi toplama ve erişimi genişletmek için derinlemesine bir araştırma yapılması.
    b. Yetkileri yükseltme, süreklilik sağlama veya diğer sistemlere geçiş yapma fırsatların aranması.
    c. İstismar sonrası aşamasında gerçekleştirilen faaliyetlerin ve hedef ortamındaki potansiyel risklerin belgelemesi.
7. **Raporlama:**
    a. Belirlenen zafiyetleri, etkilerini ve düzeltme önerilerini içeren kapsamlı bir rapor derlenmesi.
    b. Potansiyel etkilerine göre belirlenen bulguların seviyelendirilmesi.
    c. Yönetici özeti, detaylı teknik bilgiler ve genel güvenlik durumunu iyileştirmek için öneriler sağlanması.
8. **Düzeltme ve Doğrulama:**

a. Belirlenen zafiyetleri ele almak için paydaşlarla iş birliği yaparak bir eylem planı oluşturulması.
b. Önerilen düzeltme adımlarının doğru bir şekilde uygulandığının doğrulanması.
c. Düzeltme çabalarının etkinliğini doğrulamak için yeniden test veya takip değerlendirmesin yapılması.

Mobil Uygulama Sızma Testi Kontrol Listesi

1. Veri Depolama ve İletimi: Veri depolama ve iletiminin güvenliği, şifreleme, güvenli depolama mekanizmaları ve güvenli ağ iletişimi konularının gözden geçirilmesi.
2. Kimlik Doğrulama ve Yetkilendirme: Mobil uygulamadaki kimlik doğrulama ve yetkilendirme mekanizmalarının güvenliğinin değerlendirilmesi.
3. Kod İncelemesi: Mobil uygulamanın kaynak kodlarının güvenlik açıkları açısından kapsamlı bir şekilde gözden geçirilmesi.
4. Güvenli API: Mobil uygulama tarafından kullanılan API'ların güvenliği, kimlik doğrulama, erişim kontrolleri ve veri doğrulama konularında değerlendirme.
5. Platform Güvenliği: Mobil işletim sistemi platformunda uygulanan güvenlik yapılandırmalarının ve sıkılaştırma önlemlerinin değerlendirilmesi.
6. Binary Analizi: Uygulamanın binary kodunun incelenmesi, potansiyel güvenlik zafiyetlerinin ve açıklarının belirlenmesi.
7. Anti-Manipülasyon ve Tersine Mühendislik: Anti-manipülasyon önlemlerinin etkinliğinin ve tersine mühendislik girişimlerine karşı direncin test edilmesi.
8. Güvenli Veri Silme: Uygulama kaldırıldığında cihazdan hassas verilerin uygun bir şekilde silindiğinin doğrulanması.

Kullanılan Araçlar

- Nessus	- Burp Suite	- Zaproxy	- Sqlmap	- Masscan	- Ffuf
- Nmap	- Metasploit	- Wpscan	- Nikto	- SSLyze	- Websploit
- Wireshark	- Commix	- Gobuster	- Netscan	- DirBuster	- nuclei

MOBİL UYGULAMA SIZMA TESTİ BULGULARI

1. Acil Seviye Mobil Uygulama Sızma Testi Bulguları

Acil seviye bulgu tespit edilmemiştir

2. Kritik Seviye Mobil Uygulama Sızma Testi Bulguları

Kritik seviye bulgu tespit edilmemiştir

3. Yüksek Seviye Mobil Uygulama Sızma Testi Bulguları

Yüksek seviye bulgu tespit edilmemiştir

4. Orta Seviye Mobil Uygulama Sızma Testi Bulguları

4.1. **Uygulamada Güvensiz Veri Depolanması**			RS.210315.10.401
Seviye:	**Orta**		
Etkilenen Sistem:	Pegasus Cafe (.APK)	**Erişim/Profil:**	İnternet/Standart
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

Mobil uygulamalar içerisinde bulunan ve cihazda saklana dosyalar üzerinde hassas bilgi (saldırganın kullanabileceği türden her bilgi) barındırılmamalıdır. Bu tarz hassas verilerin uygulamanın cihazda sakladığı dosyalarda açık bir şekilde korumasız olarak barındırılması saldırgan kişinin bu bilgiyi düzenleyeceği saldırılarda kullanmasına sebep olacaktır.

Pegasus Cafe (.APK) uygulaması üzerinde yapılan incelemeler sunucunda çeşitli bilgilerin ele geçirilebildiği 3 farklı zafiyet tespit edilmiştir. Tespit edilen 3 farklı zafiyete ait detaylı açıklamalar ve ekran görüntüleri detayları ile aşağıda açıklanmıştır.

4.2.1 Veritabanı Açıklıkları

SQLite Veritabanı içerisindeki USER_LIST tablosunda bütün Crew listesinin (Kaptan, Kabin Amiri, Kabin Memuru) ve sicil numaralarının doğrudan görüntülenebildiği tespit edilmiştir. Veritabanı içerisinde yer alan USER_LIST tablosunda kabin ekibinin sicil numaralarına da erişim sağlanabildiğinden uygulamada bu sicil numaraları kullanılarak istenilen ekranlarda (STOK, SATIŞ vs.) oturum açılabilir.

- Dosya: /data/data/com.example.pegasus_cafe_v2/databases/FlyingCafeBaseStartup.sqlite

İncelemelere devam edildiğinde USER_LIST tablosu içerisinde DUTY_TYPE değeri IKR olan kullanıcıların Ad ve Soyad bilgilerinin sansürsüz, açık-metin olarak veritabanı içerisinde görülebildiği tespit edilmiştir. Ek olarak PREORDER tablosunun içeriği incelendiğinde uçuşlarda satış yapılan ürünlerin kimlere satıldığı bilgisinin yine açık-metin olarak görülebildiği tespit edilmiştir.

4.2.2 Operations_logs TXT İçeriği

Yapılan incelemeler sonucunda uygulamanın kullanımı sonucunda mobil cihaz üzerinde /data/data/com.example.pegasus_cafe_v2/app_flutter dizini içerisinde operation_logs adlı bir txt dosyası oluşturulduğu ve uygulamada yapılan bütün işlemlerin açık-metin olarak bu dosya içeriğine yazıldığı gözlemlenmiştir.

4.2.3 APK Dosyasının Strings ile İncelenmesi

Pegasus Cafe mobil uygulaması doğrudan "strings" komutları ile incelendiğinde uygulama geliştiricisine ait çeşitli dizin bilgilerine, özel dosya adlarına erişim sağlanabilir olduğu tespit edilmiştir.

Çözüm Önerisi:

Mobil uygulama üzerinde gerekmedikçe veri depolaması yapılmamalıdır. Veri depolaması yapılması gerektiğinde mümkünse bu verilerin şifreli bir şekilde saklanması önerilmektedir. Uygulama üzerinde kullanılan hassas verilerin dosya dizini içerisinde saklanacaksa şifrelenmesi ya da dizine yazılmadan şifreli olarak kullanılması önerilmektedir.

Kaynak:

M2: Insecure Data Storage
https://owasp.org/www-project-mobile-top-10/2016-risks/m2-insecure-data-storage
Saving Data in SQL Databases
https://developer.android.com/training/basics/data-storage/databases.html

Ekran Görüntüsü:

Tablo: USER_LIST

	CREW_ID	REGISTER_NO	NAME	SURNAME	DUTY_TYPE	USER_LIST_ID	CREW_TYPE
	Filtre	Filtre	Filtre	Filtre	Filtre	Filtre	Filtre
1	3727	2239	*ID*M	*AY*I**	K/A	1	S
2	3729	2256	*LI*	*IL*C**S	K/A	2	S
3	3731	2254	*IL*E	*UR*K	K/A	3	S
4	3732	2251	*EL*K*	*ZT*R*	K/A	4	S
5	3733	2240	*UR*U	*ST*	K/A	5	S
6	3737	2244	*AN*E	*IL*E**D	K/A	6	S
7	3740	2247	*UL*M**R	*EC*M**	K/A	7	S
8	3742	2245	*SR*	*LT*N**S	K/A	8	S
9	3744	2243	*ER*A	*KM*N	K/A	9	S
10	3750	2401	*AL*Y	*EK*N	CAP	10	C
11	3751	2404	*DN*N	*KU*A*	CAP	11	C
12	3753	2405	*US*F	*AZ*I	CAP	12	C
13	3754	2718	*AR*K	*UL*E*	CAP	13	C
14	3756	2552	*MI*	*AN*	CAP	14	C
15	3761	2506	*LP*R	*OP*L**L	K/A	15	S
16	3765	2485	*IB*R	*ZU*M**	CAP	16	C
17	3767	2500	*YS* **R	*EG*R**N	K/A	17	S
18	3789	2879	*AK*N	*KS*Y	CAP	18	C
19	3790	2562	*YD*N	*UM*U**S	CAP	19	C
20	3792	2848	*EL*N	*EV*L	CAP	20	C
21	3801	2815	*AT*L**	*IL*I*	KM	21	S
22	3803	2809	*IN*R	*IN*L	K/A	22	S
23	3805	2812	*ER*A*	*UN*Y	K/A	23	S
24	3820	2901	*YT*N	*EK*I*	K/A	24	S

- 4.2.1 Ekran Görüntüsü: USER_LIST tablosunun incelenmesi ve bütün kabin ekibinin bilgilerinin elde edilmesi

Tablo: USER_LIST

	CREW_ID	REGISTER_NO	NAME	SURNAME	DUTY_TYPE	USER_LIST_ID	CREW_TYPE
	Filtre	Filtre	Filtre	Filtre	IKR	Filtre	Filtre
1	77	4178	NADIDE...	EYUBO...	IKR	4636	
2	220	8946	SABRI	DURAN	IKR	4637	
3	228	3648	EFKAN	YILMAZ	IKR	4638	
4	263	2432	MELIKE	GUNER	IKR	4639	
5	278	2230054	DOCOAYT	DOCOAYT	IKR	4640	
6	279	2230053	DOCOADB	DOCOA...	IKR	4641	
7	671	17085	BILGE	YURDAK...	IKR	4642	
8	676	17891	ZAHIR	IMAMO...	IKR	4643	
9	689	3008602	ELIF ...	KOCAK	IKR	4644	
10	73	4353	AYDIN	TABUR	IKR	4645	
11	117	5557	ILHAN	GUMUS	IKR	4646	
12	135	6550	PINAR	UZUN	IKR	4647	
13	222	3610	UGUR	TOPAL	IKR	4648	
14	282	2230056	DOCOESB	DOCOESB	IKR	4649	
15	283	2230057	DOCOTZX	DOCOT...	IKR	4650	
16	284	2230051	DOCOD...	DOCOD...	IKR	4651	
17	384	14597	ZUHAL	YUCE	IKR	4652	
18	393	9451	GIZEM	BEKTAS	IKR	4653	
19	394	15473	SEVDA	GOKSU	IKR	4654	
20	82	4906	BERIL	AFSAR	IKR	4655	
21	233	10998	HAKAN	SIMSEK	IKR	4656	
22	244	8459	IBRAHIM	CIFTCI	IKR	4657	
23	245	11025	MUSTAFA	AYKIN	IKR	4658	

- 4.2.1 Ekran Görüntüsü: USER_LIST tablosu içerisinde sansürsüz olarak görüntülenebilen Ad/Soyad/Sicil kabin ekibi bilgileri

Tablo: PREORDER

	PREORDER_ID	FLIGHT_INFO_ID	NAME	LAST_NAME	SEAT_NO	PNR_NO	SSR_CODE	BO_PREORDER
	Filtre	Filtre	Filtre	Filtre	Filtre	Filtre	Filtre	Filtre
1	1	2043826	DAVID	DENEME	15B	QBX3XE	HBRA	38664603
2	2	2043826	JENNIFER	DENEME	15A	QBX3XE	HBRA	38664604
3	3	2043826	DEBASISH	DENEME	8A	SP745G	HBRA	38664605
4	4	2043826	MANISA	DENEME	8B	SP745G	HBRA	38664606
5	5	2043826	ABYARTH KUMAR	DENEME	8C	SP745G	HBRA	38664607
6	6	2043826	JULIE	DENEME	2A	QC54MT	HBRA	38664608
7	7	2043826	JAMES	DENEME	2B	QC54MT	HBRA	38664609
8	8	2043826	ALISON	DENEME	1F	QC2VFE	HBRA	38664610
9	9	2043826	GARY	DENEME	1E	QC2VFE	HBRA	38664611
10	10	2043826	COLIN FRANK	DENEME	1B	QBXHVN	HBRA	38664612
11	11	2043826	LYNNE	DENEME	1C	QBXHVN	HBRA	38664613
12	12	2043826	OĞUZ	DENEME	3A	UWTKNB	HBRA	38664614
13	13	2043826	LYNN	DENEME	2F	QVJVL4	HBRA	38664615
14	14	2043826	PHILIP	DENEME	2E	QVJVL4	HBRA	38664616
15	15	2043473	AOURAGH	DENEME	1A	WL4VYK	BPSW	38664662
16	16	2043473	NADIA	DENEME	1B	WL4VYK	BPSW	38664663
17	17	2043473	DYKRA	DENEME	1C	WL4VYK	BPSW	38664664
18	18	2043473	MOHAMED AMIN	DENEME	1D	WL4VYK	BPSW	38664665
19	19	2043582	ISA	DENEME		VN34BK	MLKF	38664648
20	20	2043582	ZEYNEP	DENEME		VN34BK	HMCH	38664649
21	21	2043598	ECE	DENEME		ZBU9TP	HBRA	38664509
22	22	2043598	HÜSEYIN	DENEME		ZBU9TP	HBRA	38664510
23	23	2043598	ELIF	DENEME		ZBU9TP	HBRA	38664511

- 4.2.1 Ekran Görüntüsü: PREORDER tablosu içerisinde ürün satışı yapılan yolcu bilgilerinin doğrudan görüntülenebilmesi

```
:/data/data/com.example.pegasus_cafe_v2/app_flutter # ls -la
total 16
drwxrwx--x 2 u0_a91 u0_a91 4096 2024-05-09 12:18 .
drwx------ 7 u0_a91 u0_a91 4096 2024-05-09 12:14 ..
-rw------- 1 u0_a91 u0_a91 1127 2024-05-09 12:18 operation_logs_09_05_2024_12_18_49.txt
-rw------- 1 u0_a91 u0_a91   84 2024-05-09 12:20 transferdatex.hive
-rw------- 1 u0_a91 u0_a91    0 2024-05-09 12:36 transferdatex.lock
:/data/data/com.example.pegasus_cafe_v2/app_flutter # cat operation_logs_09_05_2024_12_18_49.txt
OperationLogId: 1, TerminalId: 861353049690085, FlightInfoId: -1, CreateDate: 2024-05-09 12:15:08, CrewId: 3727, CrewGroupId: -1, MsgId: 1, Detail: İkram modülüne giriş yapıldı.
OperationLogId: 2, TerminalId: 861353049690085, FlightInfoId: -1, CreateDate: 2024-05-09 12:15:10, CrewId: 3727, CrewGroupId: -1, MsgId: 1, Detail: Backoffice transfer ekranından çıkıldı.
OperationLogId: 3, TerminalId: 861353049690085, FlightInfoId: -1, CreateDate: 2024-05-09 12:15:20, CrewId: 3727, CrewGroupId: -1, MsgId: 1, Detail: İkram modülüne giriş yapıldı.
OperationLogId: 4, TerminalId: 861353049690085, FlightInfoId: -1, CreateDate: 2024-05-09 12:15:26, CrewId: 3727, CrewGroupId: -1, MsgId: 1, Detail: Backoffice transfer işlemi başlatıldı.
OperationLogId: 5, TerminalId: 861353049690085, FlightInfoId: -1, CreateDate: 2024-05-09 12:18:32, CrewId: 3727, CrewGroupId: -1, MsgId: 1, Detail: İkram modülüne giriş yapıldı.
OperationLogId: 6, TerminalId: 861353049690085, FlightInfoId: -1, CreateDate: 2024-05-09 12:18:35, CrewId: 3727, CrewGroupId: -1, MsgId: 1, Detail: Backoffice transfer işlemi başlatıldı.
:/data/data/com.example.pegasus_cafe_v2/app_flutter #
```

- 4.2.2 Ekran Görüntüsü: operations_log.txt içeriğinde uygulama üzerinde yapılan bütün işlemlerin görüntülenebilmesi

```
sh-3.2# strings app-profile.apk | grep sahin
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/uplift/uplift_list/repo/uplift_list_repository.dart
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/sales/sale_add_product/ui/widget/sale_add_product_card.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/source_span-1.10.0/lib/src/highlighter.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/hive-2.2.3/lib/src/object/hive_collection.dart
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/preorder/bloc/preorder_bloc.dart
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/stock/stock_out_alert/stock_out_page/ui/widgets/stock_out_exit_a
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/source_span-1.10.0/lib/src/span_exception.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/equatable-2.0.5/lib/src/equatable_utils.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/equatable-2.0.5/lib/src/equatable_config.dart
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/stock/add_product/ui/widget/add_product_card.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/http-1.2.0/lib/src/io_client.dart
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/stock/add_product/repo/add_product_repository.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/logger-2.0.2+1/lib/src/printers/pretty_printer.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/plugin_platform_interface-2.1.8/lib/plugin_platform_interface.dart
file:///C:/Users/sahin/OneDrive/Belgeler/pegasusmobile/lib/pages/stock/add_product/ui/widget/add_product_type_selection.dart
file:///C:/Users/sahin/AppData/Local/Pub/Cache/hosted/pub.dev/permission_handler_platform_interface-3.12.0/lib/permission_handle
```

- 4.2.3 Ekran Görüntüsü: APK dosyasının strings ile incelenmesi sonucunda uygulamaya ait hassas verilerin ve iç dizin bilgilerinin görüntülenebilir olması

5. Düşük Seviye Mobil Uygulama Sızma Testi Bulguları

5.1. Uygulama Hata Mesajlarında Bilgilerin Erişilebilir Olması	RS.210315.10.501
Seviye: Düşük	

Etkilenen Sistem:	appprep.pegasusum.com:5019	**Erişim/Profil:**	İnternet/Standart
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

Web sunucuları kurulumda varsayılan hata mesajları ile gelmektedir. Uygulama üzerindeki hata mesajları düzenlenmeden kullanılırsa, kullanıcılar/saldırganlar hata mesajlarını inceleyerek web sunucusu hakkında sürüm, yama seviyesi gibi bilgilere ulaşabilir.

Yapılan incelemeler sonucunda uygulamada Stack Trace'nin aktif olduğu dolayısıyla hata mesajlarının çeşitli bilgi ifşalarına sebep verdiği tespit edilmiştir. İlgili hata mesajlarında kullanılan web servis, kullanılan veritabanı, iç dizin ifşası gibi çeşitli bilgilerin son kullanıcıya yansıtıldığı gözlemlenmiştir. Uygulamanın canlıya çıkması aşamalarında stack trace devre dışı bırakılmalıdır.

- https://appprep.pegasusum.com:5019/Transfer.svc/TermFinished
- https://appprep.pegasusum.com:5019/Transfer.svc/TermFinished?sessionID=1337'

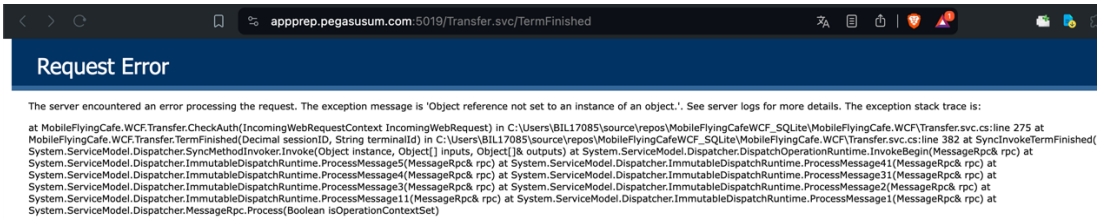
Çözüm Önerisi:

Web sunucuları ve uygulama üzerindeki hata mesajlarının düzenlenmesi, sunucu ve uygulama bazlı hata raporlarının kapatılması tavsiye edilmektedir. Hassas olabilecek her türlü verinin kontrolsüz bir şekilde erişimden kaldırılması tavsiye edilmektedir.

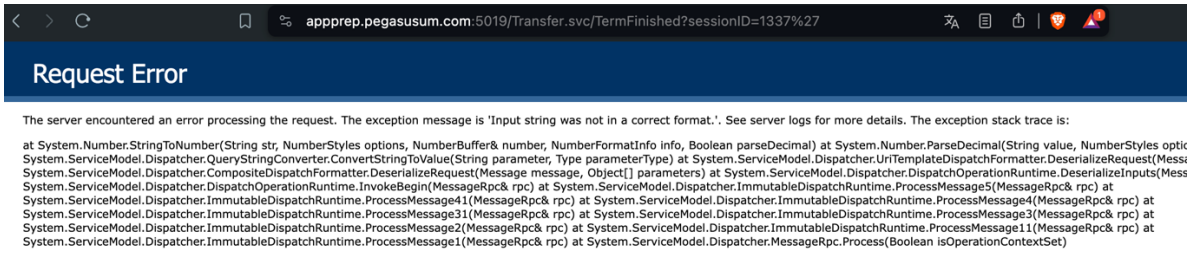
Kaynak:

HTTP Errors <httpErrors>
https://docs.microsoft.com/en-us/iis/configuration/system.webserver/httperrors/
How to Configure a Custom 404 Error Page in Microsoft IIS Server
https://www.bruceclay.com/blog/microsoft-iis-custom-404-error-page-configuration/

Ekran Görüntüsü:



- Ekran Görüntüsü: HTTP Yanıtında dizin bilgisinin tespit edilmesi



- Ekran Görüntüsü: HTTP Yanıtında dizin bilgisinin tespit edilmesi

5.2. Mobil Uygulama Debugging Özelliğinin Aktif Olması		RS.210315.10.502
Seviye:	**Düşük**	
Etkilenen Sistem: Pegasus Cafe (.APK)	**Erişim/Profil:**	İnternet/Standart
	Etki Biçimi:	Gizliliğin Bozulması
	Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

APK Manifest dosyası içerisinde 'android:debuggable' işaretli uygulamalar Hata ayıklama ve kodun çalışma yapısını kapsamaktadır. Bu işaretin aktif olması, saldırganların uygulama kodlarına erişim sağlamasına ve derlemesine olanak sağlamaktadır.

Yapılan incelemeler sonucunda Pegasus Cafe mobil uygulamasında 'android:debuggable' parametresinin aktif olduğu gözlemlenmiştir.

Çözüm Önerisi:

Mobil uygulama içerisindeki Manifest dosyasındaki 'android:debuggable' değerinin False olarak düzeltilmesi gerekmektedir.

Kaynak:

android:debuggable
https://developer.android.com/guide/topics/manifest/application-element.html#debug

Ekran Görüntüsü:

AndroidManifest.xml

```
1.  <?xml version="1.0" encoding="utf-8"?>
2.  <manifest android:versionCode="36" android:versionName="1.2.34" android:compileSdkVersion="33" android:compileSdkVersionCodename="13" package="com.example.pegasu
3.    xmlns:android="http://schemas.android.com/apk/res/android">
4.      <uses-sdk android:minSdkVersion="25" android:targetSdkVersion="30" />
5.      <uses-permission android:name="android.permission.INTERNET" />
6.      <uses-permission android:name="android.permission.CAMERA" />
7.      <uses-permission android:name="android.permission.WRITE_EXTERNAL_STORAGE" />
8.      <uses-permission android:name="android.permission.READ_EXTERNAL_STORAGE" />
9.      <uses-permission android:name="android.permission.ACCESS_FINE_LOCATION" />
10.     <uses-permission android:name="android.permission.ACCESS_COARSE_LOCATION" />
11.     <uses-permission android:name="android.permission.ACCESS_WIFI_STATE" />
12.     <uses-permission android:name="android.permission.CHANGE_WIFI_STATE" />
13.     <uses-permission android:name="android.permission.ACCESS_NETWORK_STATE" />
14.     <uses-permission android:name="android.permission.CHANGE_NETWORK_STATE" />
15.     <uses-permission android:name="android.permission.READ_PHONE_STATE" />
16.     <uses-permission android:name="android.permission.NEARBY_WIFI_DEVICES" />
17.     <uses-permission android:name="android.permission.READ_PRIVILEGED_PHONE_STATE" />
18.     <application android:label="Pegasus Cafe" android:icon="@mipmap/ic_launcher" android:name="android.app.Application" android:debuggable="true" android:extractl
19.         <activity android:theme="@style/LaunchTheme" android:name="com.example.pegasus_cafe_v2.MainActivity" android:debuggable="false" android:exported="true" a
20.             <meta-data android:name="io.flutter.embedding.android.NormalTheme" android:resource="@style/NormalTheme" />
21.             <intent-filter>
```

- Ekran Görüntüsü: Pegasus Cafe – Android Debuggable Aktif Olması

5.3. Yetki Kontrolü Eksikliği			RS.210315.10.503
Seviye:	**Düşük**		
Etkilenen Sistem:	Pegasus Cafe (.APK)	**Erişim/Profil:**	İnternet/Standart
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

Sistem yetkisine sahip cihazların kullanılması sonucunda, uygulama bütünlüğünü riske sokar. Bu yetkilerin uygulama tarafından kontrol edilmesi son derece önemlidir. Aksi takdirde uygulamaya ait tüm verilerin ifşa olmasına neden olmaktadır.

Yapılan incelemelerde Pegasus Cafe mobil uygulaması genel olarak localinde işlem yaparak çalıştığından gerçekleştirilen işlemlere ait verileri doğrudan cihaz içerisine ve APK uygulamasının veritabanına kaydettiği gözlemlenmiştir. Dolayısıyla uygulama üzerinde yapılan işlemlere ait verilerin doğrudan ele geçirilebilir olması sebebi ile mobil uygulamada Rootlu cihaz yetki kontrollerinin devreye alınması önerilmektedir.

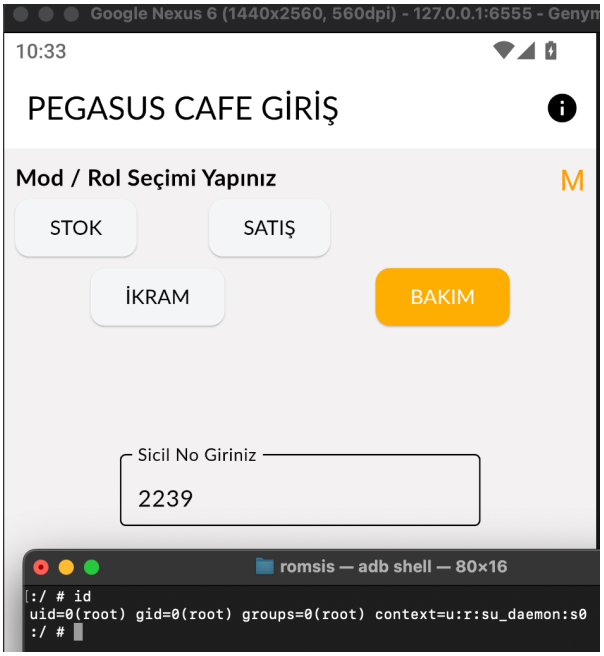
Çözüm Önerisi:

Mobil uygulama üzerinde yetki kontrollerinin sağlanarak Root/Jailbroken cihazlarda mobil uygulamanın çalışamayacağı şekilde ek güvenlik önlemlerinin alınması önerilmektedir.

Kaynak:

Android Root Detection Techniques
https://blog.netspi.com/android-root-detection-techniques/
Root Detection and Evasion
http://resources.infosecinstitute.com/android-hacking-security-part-8-root-detection-evasion/

Ekran Görüntüsü:



- Ekran Görüntüsü: Rootlu cihaz ile Pegasus Cafe uygulamasının çalıştırılabilmesi